

Examen de seguridad web

Duración: 120 minutos. Laboratorio autorizado.

1. Diferencia IDOR, autenticación débil y control client-side.
2. Interpreta tres respuestas de una prueba SQL booleana y descarta un falso positivo.
3. Construye una prueba de command injection para un contexto `sh -c` y contrástala con `argv`.
4. Explica una ruta traversal por niveles y su normalización.
5. Diseña confirmación y control negativo para SSRF HTTP.
6. Separa aceptación, almacenamiento, servicio y ejecución en un upload.
7. Adapta una prueba SSTI cuando la expresión aparece literal.
8. Propón mitigaciones para SQLi, SSRF, LFI y upload.
9. Analiza una petición JSON con JWT y un identificador de objeto; prioriza pruebas.
10. Escenario práctico: discovery revela `/api`, upload y parámetro `url`. Construye un plan de ocho pasos, evidencia esperada, criterios de descarte y una cadena de impacto sin exceder la primitiva confirmada.

Rúbrica

Criterio	Puntos
Identificación y mecanismo	25
Construcción razonada	30
Adaptación y falsos positivos	20
Evidencia, impacto y mitigación	25